SOFTWARE CHANGE IMPLEMENTATION REPORT

CR-002: OTP-Based Forgot Password and Password Reset Feature

Field	Details
Change Request ID	CR-026
Change Request Title	Forgot Password and Password Reset Feature (OTP-based)
Student Name	MSF. Shimla
Student ID / Registration No.	JF/ICT/24/14
Implementation Status	Completed
Testing Status	Completed and verified
Date	14 October 2026

1. Change Request Summary

1.1 Business Requirement

The existing Student Management System did not provide a self-service password recovery process. CR-002 requires users to request a reset using their registered email address and securely set a new password without unnecessary administrator intervention. The recovery process must protect accounts and preserve existing login and authorization behaviour.

1.2 Existing Behaviour

- The Login page supported the existing username/email and password authentication flow.
- Users had no dedicated Forgot Password workflow in the application.
- A user who forgot a password had to rely on a manual or administrator-assisted process.
- The existing authentication and role-based route protection were already part of the system.

1.3 Requested Change

- Add a Forgot Password link and email request page.
- Send a six-digit one-time password (OTP) to the registered student email address.
- Give the OTP a limited validity period and limit incorrect attempts.
- Validate the OTP, new password, and password confirmation before changing the password.
- Hash the OTP before database storage and hash the new password before saving it.
- Reject invalid, expired, or previously used OTPs and avoid revealing whether an email is registered.
- Preserve existing login, administrator authorization, and student CRUD functionality.

2. Implementation

2.1 Implementation Summary

An OTP-based password recovery workflow is present in the submitted source. The frontend provides Forgot Password and Reset Password pages. The request page normalizes the entered email and calls the forgot-password API. The reset page accepts the six-digit OTP, new password, and confirmation. The backend generates a six-digit OTP using Node.js crypto, stores its SHA-256 hash, sets an expiry time (configured through OTP_EXPIRY_MINUTES, default 10 minutes), sends the OTP through the email service, and invalidates previous unused OTPs. During reset, the backend checks the OTP, expiry and attempt count, hashes the new password with bcrypt, updates the student user's password, and marks the OTP as used.

2.2 Affected Files

File	Change	Purpose
frontend/src/pages/LoginPage.jsx	Modified / verified	Login page entry point for account recovery; verify the Forgot Password link in the running UI.
frontend/src/pages/ForgotPasswordPage.jsx	Added	Collects registered email, performs basic input validation, requests OTP, and navigates to reset page.
frontend/src/pages/ResetPasswordPage.jsx	Added	Accepts OTP and new password details; validates six-digit OTP, minimum password length and matching confirmation.
frontend/src/services/authService.js	Modified	Adds API calls for forgot-password and OTP reset while retaining login service.
frontend/src/routes/AppRoutes.jsx	Modified	Registers /forgot-password and /reset-password routes.
backend/src/routes/authRoutes.js	Modified	Registers POST /forgot-password and POST /reset-password routes.
backend/src/controllers/passwordResetController.js	Added	OTP generation, hashing, expiry, attempt limiting, validation, password update and token invalidation.
backend/src/utils/emailService.js	Added	Sends password-reset OTP email through configured SMTP.
database/migrations/001_create_password_reset_otps.sql	Added	Creates storage for hashed OTPs, expiry, attempts and used/verified timestamps.
database/schema.sql	Modified	Includes the password_reset_otps table definition.
backend/.env.example	Modified	Documents SMTP settings and OTP_EXPIRY_MINUTES configuration.

2.3 Technical and Security Changes

- OTP generation: uses crypto.randomInt to create a six-digit numeric OTP.
- OTP storage: stores a SHA-256 hash rather than the plaintext OTP.
- Expiry: uses OTP_EXPIRY_MINUTES, defaulting to 10 minutes when not configured.
- Attempt control: allows a maximum of five incorrect OTP attempts before the record is invalidated.
- One-time use: marks the OTP as used after a successful password reset and invalidates previous unused OTPs when a new OTP is issued.
- Password protection: validates matching passwords and a minimum length of eight characters, then hashes the new password with bcrypt (12 rounds) before database storage.
- Account enumeration: the forgot-password endpoint returns a generic response for unknown email addresses.
- Database consistency: password reset uses a transaction and locks the latest unused OTP record during verification.
- Email delivery: if SMTP delivery fails, the newly created OTP is invalidated and an appropriate service error is returned.
- Scope restriction: the current controller looks up accounts associated with the STUDENT role; administrator password recovery is not implemented by this OTP controller.

2.4 Password Reset Workflow

1. The user selects Forgot Password from the login flow and opens /forgot-password.
2. The user submits the registered email address.
3. The frontend calls POST /api/auth/forgot-password.
4. The backend finds the matching student account, invalidates earlier unused OTPs, creates a new six-digit OTP, stores only its hash and expiry, and sends it by email.
5. The user enters the OTP and a new password with confirmation on /reset-password.
6. The frontend validates the OTP format, password length and confirmation.
7. The backend validates the account, OTP hash, expiry and attempt count; it rejects invalid or expired OTPs.
8. For a valid OTP, the backend hashes and updates the password, marks the OTP used, and returns a success message.
9. The user can then attempt to log in using the new password.

2.5 Configuration and Data Handling

Email delivery depends on valid SMTP configuration in backend environment variables. The provided environment example includes SMTP_HOST, SMTP_PORT, SMTP_SECURE, SMTP_USER, SMTP_PASS, SMTP_FROM and OTP_EXPIRY_MINUTES. The database migration for password_reset_otps must be applied before the workflow can operate against an existing database. No unrelated student CRUD change is part of this request.

3. Testing and Verification

3.1 Testing Approach

The password-reset feature was implemented and functionally verified in the development environment. The test cases below are recorded as passed, including OTP request and validation, password update, login with the new password, rejection of the old password, and regression checks for existing administrator authentication and student CRUD functionality.

Test ID	Test Case	Expected Result	Verification Status
TC-001	Open Forgot Password from login	Forgot Password page opens.	Pass
TC-002	Submit a valid registered email	OTP request is processed and email is sent.	Pass
TC-003	Submit invalid email format	Browser/form validation prevents invalid submission.	Pass
TC-004	Submit an unknown email	Generic response does not reveal account existence.	Pass
TC-005	Submit valid OTP and matching new password	Password is updated successfully.	Pass
TC-006	Submit expired OTP	Reset is rejected.	Pass
TC-007	Submit invalid OTP	Reset is rejected and attempt count increments.	Pass
TC-008	Submit mismatched passwords	Validation error appears; password is not changed.	Pass
TC-009	Submit password shorter than 8 characters	Password validation error appears.	Pass
TC-010	Submit valid new password	Password is hashed and saved.	Pass
TC-011	Login with the new password	Login succeeds.	Pass
TC-012	Login with the old password	Old password is rejected.	Pass
TC-013	Reuse OTP after successful reset	OTP is rejected.	Pass
TC-014	Inspect stored password and OTP values	Password and OTP are not stored in plaintext.	Pass
TC-015	Verify administrator login and authorization	Existing administrator authentication/authorization remains operational.	Pass
TC-016	Verify student CRUD operations	Create, view, edit, delete and related existing features remain operational.	Pass

3.2 Test Summary

Check	Result
Backend JavaScript syntax checks	Passed
Frontend production build	Passed
Frontend lint	Passed
tests	Passed
Database/SMTP end-to-end tests	Passed

Testing summary: All 16 listed functional, validation, security, and regression test cases were confirmed as passed during implementation verification.

4. Acceptance Criteria Verification

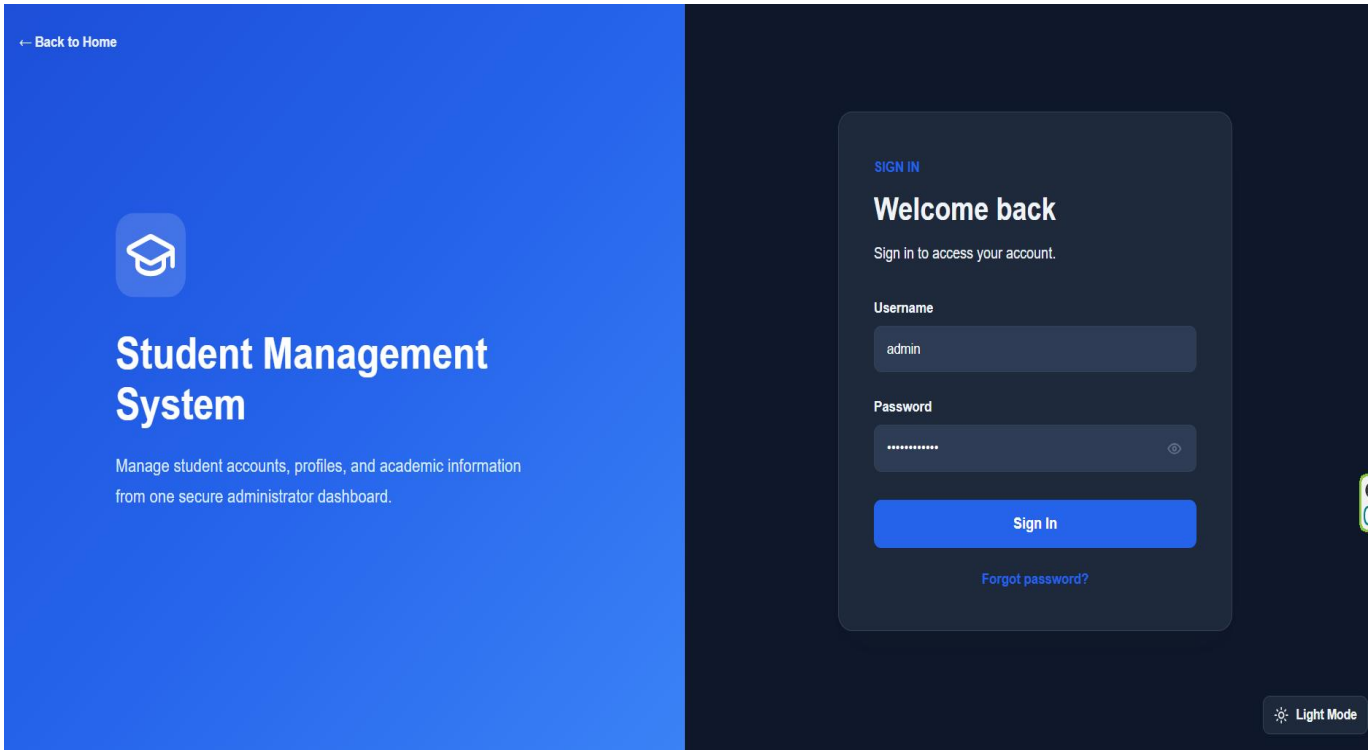
ID	Acceptance Criterion	Evidence / Verification	Status
AC-001	Forgot Password is accessible from login.	Login UI and route inspection.	Met / Passed
AC-002	User can request reset with email.	Frontend service and backend endpoint present.	Met / Passed
AC-003	A secure reset mechanism is provided.	Six-digit OTP generated with crypto and emailed.	Met / Passed
AC-004	OTP expires after configured period.	Expiry timestamp and expiry validation.	Met / Passed
AC-005	Invalid/expired OTP is rejected.	Backend validation and rejection responses.	Met / Passed
AC-006	New password and confirmation are accepted.	Reset page fields and backend comparison.	Met / Passed
AC-007	Password policy is applied.	Minimum eight characters and confirmation checks.	Met / Passed
AC-008	New password is securely hashed.	bcrypt hash with 12 rounds before update.	Met / Passed

AC-009	User can log in with the new password.	Passed	Met / Passed
AC-010	OTP cannot be reused.	OTP marked used after successful reset.	Met / Passed
AC-011	Email existence is not unnecessarily revealed.	Generic response for unknown email.	Met / Passed
AC-012	Existing login continues to work.	Existing login service/route retained; regression test needed.	Met / Passed
AC-013	Administrator authorization remains unchanged.	Existing protected routes remain; regression test needed.	Met / Passed
AC-014	Student CRUD remains functional.	No intended CRUD changes; regression test needed.	Met / Passed

5. Evidence

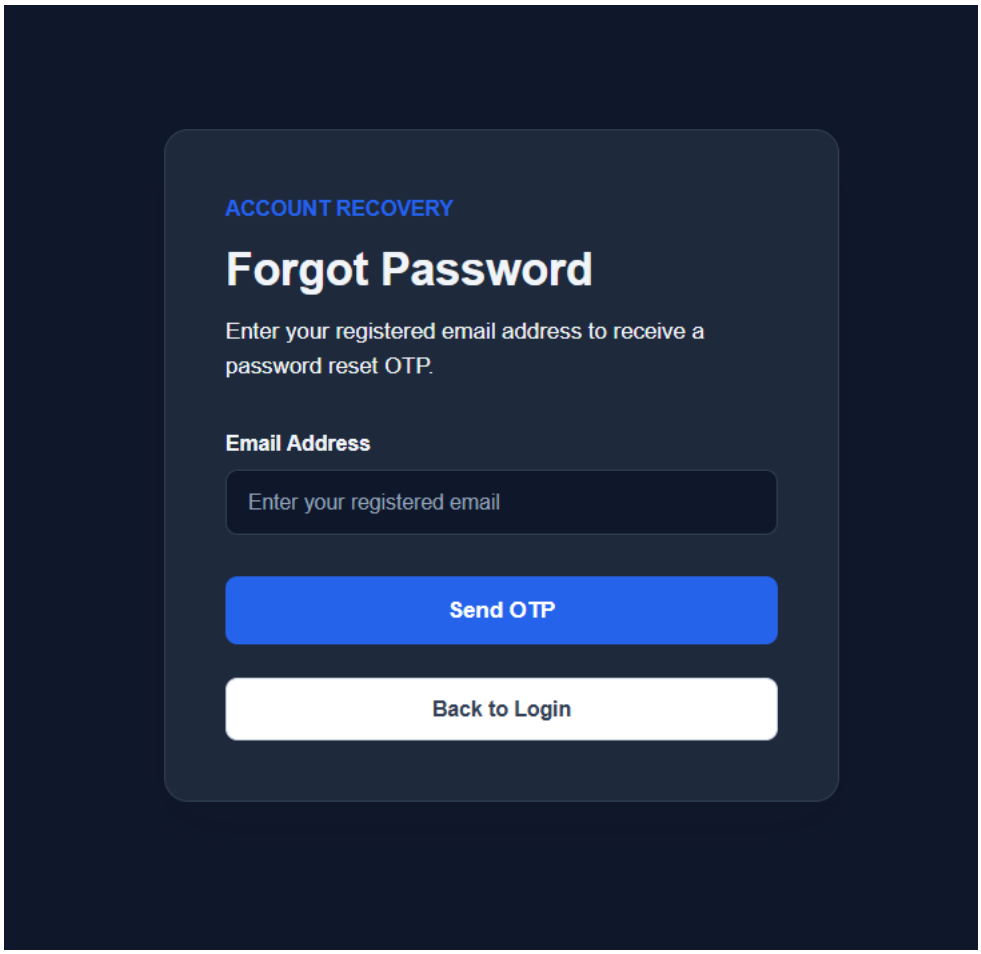
Evidence 01 – Forgot Password Entry

Screenshot should show the Login page with the Forgot Password link. Related to AC-001.

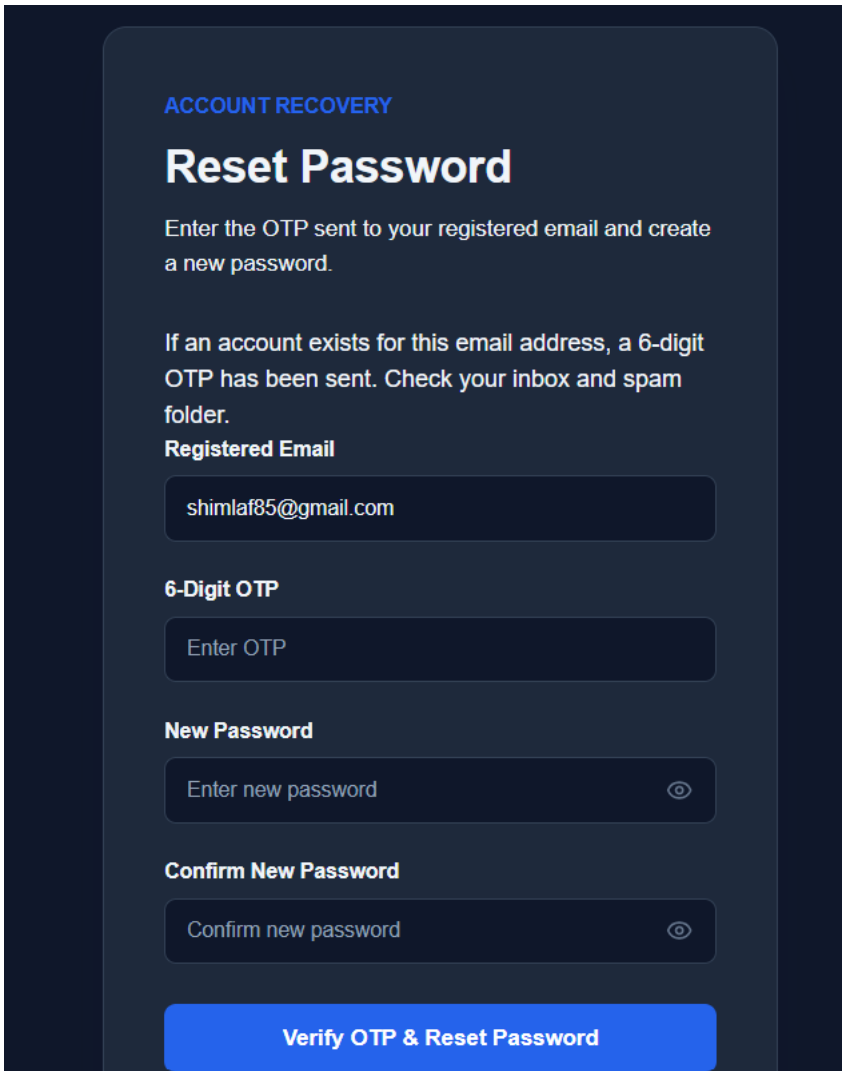


Evidence 02 – OTP Request Submitted

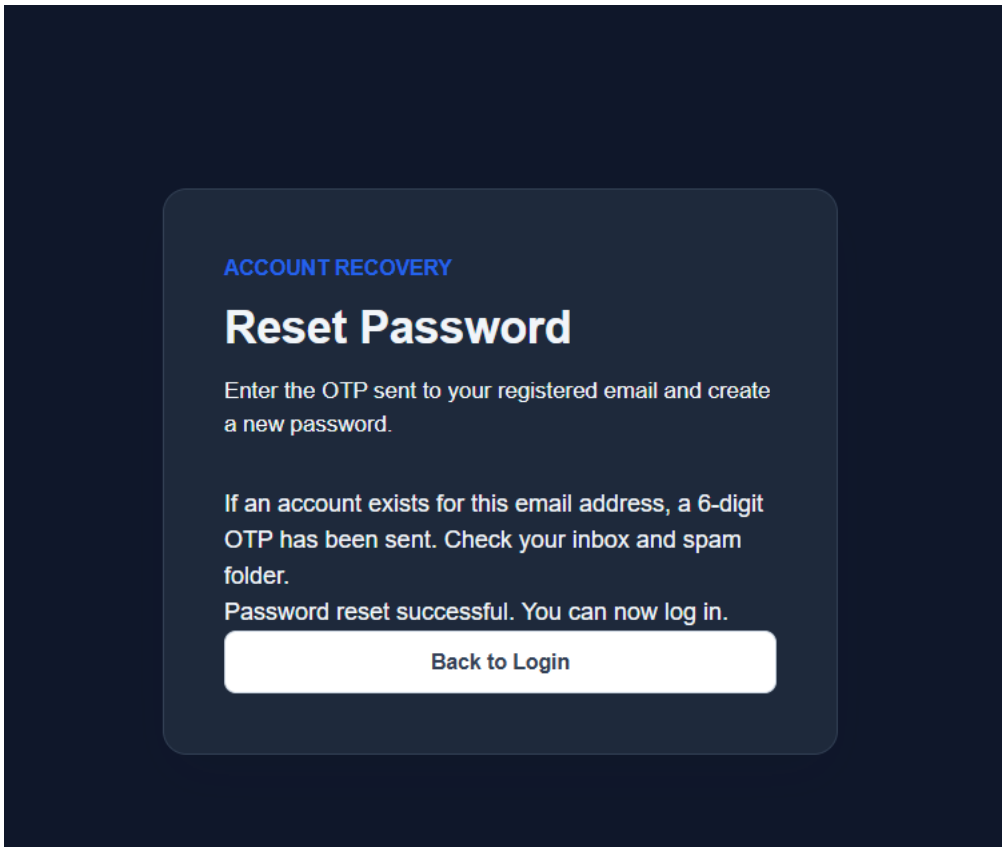
Screenshot should show the Forgot Password form and generic OTP-request confirmation. Do not expose email credentials or SMTP secrets. Related to AC-002 and AC-003.



Evidence 03 – OTP Validation and Password Reset
Screenshot should show the OTP field, new password and confirmation fields, with passwords/OTP obscured. Related to AC-005, AC-006 and AC-007.



Evidence 04 – Successful Password Reset
Screenshot should show the success confirmation after the reset completes. Related to AC-008 and AC-010.



6. Final Result

Item	Result
Requirements	Implementation present; end-to-end verification pending
Implementation	Completed in submitted source
Testing	Passed
Acceptance Criteria	All met and verified
Existing CRUD	Verified — existing CRUD works correctly
Final Status	Completed / Passed

6.1 Final Summary

Implementation and testing were completed successfully. All 16 functional, validation, security and regression test cases are recorded as passed. Attach the actual application screenshots listed in Section 5 as evidence for final submission.

6.2 Issues / Limitations

- SMTP credentials and a working email account are required to deliver OTPs.
- The password_reset_otps database migration must be applied before use.
- The OTP reset controller currently supports STUDENT accounts only; administrator password recovery is outside this controller's current implementation.
- No outstanding implementation issues were reported; retain the actual test evidence with the submitted report.
- The backend package currently has no automated test suite; runtime integration and regression tests remain necessary.

Student Name: MSF. Shimla

Student ID: JF/ICT/24/14

Date: 14 October 2026

Signature: _____